Business Rules: RAG-Diary

> Domain rules that limit what the system may and may not do. Unlike functional requirements, they are conditions of correctness rather than behaviour a user commands.

> Thai version: BUSINESS-RULES.md

1. Document control

Item	Detail
Document	Business Rules
Version	1.0
Prepared	15 October 2026
Author	Business Analyst / System Analyst (project owner)
Status	Reviewed, round 1 (25 October 2026)
Related documents	SRS, USE-CASES, NFR-SPEC, DFD-PRIVACY

2. Purpose and meaning

This document answers one question: which conditions must the system always hold, so the data stays correct, safe and compliant?

The difference from the other documents: a functional requirement says what the system does, while a business rule says what counts as correct. The system may, for example, offer a delete function, but a rule decides that deletion must also remove the semantic index.

3. Rule groups

Group	IDs	Topic
Data access	BR-01, BR-02, BR-09, BR-10	Access rights and data isolation
Data and index lifecycle	BR-03, BR-04, BR-07, BR-08	Index readiness, deletion and export
AI use and consent	BR-05, BR-06	Grounding the source and sending data out

4. Business rules

ID	Rule	Reason	How it is enforced	Impact if broken	Related FR / UC
BR-01	Every entry has one owner, and one user cannot read another user's data	Diary privacy is the product's core value	Enforced in the database with row-level security	Data leaks and trust is lost	FR-15, all UCs
BR-02	Every endpoint that touches data requires authentication first	Data belongs only to the signed-in user	Session checked at the API layer on every path	A visitor reaches entries without authorisation	FR-15, NFR-02, UC-01
BR-03	An entry can only be found by semantic search once it has an embedding	Search depends on the vector index being present	An embedding is built as soon as an entry is written	Search misses entries and results are unreliable	FR-05, UC-02
BR-04	When an entry is edited, its semantic index must be rebuilt	Stops results from pointing at old text	A new embedding is built after every edit	Results contradict the current text	FR-05, FR-07, UC-02, UC-03
BR-05	AI answers must be grounded only in the entries of the user who asked	Stops answers from mixing in someone else's data	Search runs only against the signed-in user's index	Wrong answers and data leakage	FR-10, UC-04
BR-06	The user must consent before the system sends data out for processing	Meets the personal data requirements	A notice and consent request appear before any AI feature	Breach of the privacy requirements	NFR-03, FR-05, FR-09, FR-10, FR-11, FR-12, UC-02, UC-04, UC-05
BR-07	Deleting all data must remove the entries and the semantic index completely	The user must be able to delete for real, with no trace left	Every layer the user owns is deleted	Data remains after deletion	FR-14, UC-06
BR-08	The export file must contain every entry, and only the requesting user's	Users own the right to take their data with them	Export only the data of the authenticated user	Incomplete export, or someone else's data inside	FR-13, UC-06
BR-09	A tag must belong to the same account as its entry	Stops tags crossing accounts	Tags are bound to entries within the same user	Confusing data structure	FR-04, UC-02

ID	Rule	Reason	How it is enforced	Impact if broken	Related FR / UC
BR-10	A visitor who is not signed in cannot reach any entry	Entries are never shown without authentication	Every protected page redirects to login	Data exposed by accident	FR-15, all UCs (redirect when there is no session)

5. Decision tables

DT-1 Semantic search

Signed in	Has embedding	Query not empty	System behaviour
No	-	-	Refuse and redirect to the login page
Yes	No	No	Say the index is not ready and ask for a query first
Yes	No	Yes	Say the index is not ready and ask the user to try later
Yes	Yes	No	Ask for a query
Yes	Yes	Yes	Search that user's index and show results, or say none were found

DT-2 Delete all data

User confirmed	Data exists	System behaviour
No	-	Show the confirmation dialog and delete nothing
Yes	Yes	Delete all of the user's entries and semantic index, then confirm
Yes	No	Say there is nothing to delete

6. Assumptions

- BR-01, BR-02, BR-07, BR-08 and BR-10 are enforced by database and API mechanisms, not only by text in a document.
- BR-06 is already enforced on the client by the consent gate (AiConsentProvider) before every AI call, and can be withdrawn in settings. Recording account-level consent evidence and the legal wording still needs review with the data protection officer.
- Every rule is referenced in the SRS at the related requirement, so it can be traced.

7. References

Document	Relationship
SRS	The requirements these rules enforce
USE-CASES	The events where the rules apply
NFR-SPEC	Rules that must be measured
DFD-PRIVACY	The data paths these rules protect